

Botium Toys - Scope, Goals & Risk Assessment

Portfolio case study: small business security posture and prioritized control recommendations

Scope

- Business operations, employee accounts/endpoints, customer and payment-related data, network/internet access, inventory systems, and core business applications.
- Objective is to identify material control gaps, prioritize improvements, and improve readiness for security and compliance obligations.

Goals

- Reduce unauthorized access and credential-based attacks.
- Protect sensitive customer/business information in transit and at rest.
- Improve detection through centralized logging and intrusion monitoring.
- Strengthen recoverability through tested backups.
- Establish repeatable access reviews, policies, and remediation tracking.

Risk Summary

Risk	Likelihood	Impact	Score	Priority	Recommended controls
Weak access controls / excessive privileges	4	5	20	Critical	RBAC, MFA, least privilege, quarterly access review, separate admin accounts
Limited encryption of sensitive data	3	5	15	High	Approved TLS, encryption at rest, key ownership and rotation
Insufficient monitoring / IDS capability	4	4	16	High	Central logs, endpoint monitoring, IDS/IPS where appropriate, alert ownership
Backups not consistently validated	3	5	15	High	Protected backups, restore tests, documented RTO/RPO
Patch / vulnerability exposure	4	4	16	High	Asset inventory, vulnerability scans, risk-based patch SLAs, validation
Phishing / social engineering	4	4	16	High	MFA, email controls, awareness training, reporting process
Third-party / vendor access	3	4	12	High	Vendor review, access expiry, SSO/MFA, contract and data controls

Prioritized Action Plan

- **Immediate:** Enforce MFA for administrators and remote access, patch critical internet-facing systems, validate backups, and remove unnecessary privileged access.
- **Near term:** Centralize security logs, implement recurring access reviews, document incident escalation, and confirm encryption coverage.
- **Ongoing:** Vulnerability scanning, security-awareness reinforcement, vendor reviews, restore testing, exception tracking, and risk-register updates.

Management Metrics

Metric	Why it matters
MFA coverage for privileged users	Measures protection of highest-impact identities
Critical vulnerabilities past SLA	Shows unresolved technical exposure
Privileged accounts reviewed on time	Measures governance and least privilege
Restore tests completed / passed	Measures recovery confidence
Security events centrally logged	Measures monitoring coverage
High risks without active treatment	Measures risk-management accountability

Conclusion

The recommended sequence prioritizes identity, vulnerability remediation, logging, encryption, and recovery because those controls reduce the likelihood or impact of multiple risk scenarios at once. Remaining risks should be tracked with accountable owners, target dates, validation evidence, and documented acceptance where remediation is deferred.